

# Cross-Cutting Gap Analysis — Design System × MVP Corpora Consistency Audit

## Cross-Cutting Gap Analysis — Design System × MVP Corpora Consistency Audit

**Revision:** 2 **Last modified:** 2026-07-04T17:00:00Z **Status:** Audit / recommendations only — no source docs edited by this document's author

**STATUS UPDATE (2026-07-04T17:00:00Z, added after an independent re-review found parts of this document stale against the live repo).** Several recommendations below were ACTIONED by a parallel workstream shortly after this audit was written, and an independent adversarial review (not the fixing agent's own report) confirmed the fixes are real: the brand-color reconciliation (§1) landed in MVP2\_MOBILE\_APPS.md, MVP2\_WEB\_CLIENT.md, MVP2\_DESKTOP\_APPS.md, MVP2\_UI\_UX\_SPEC.md; the anti-bluff testing-doctrine gap (§2) was closed with a new §8.0 in MVP2\_SECURITY\_PERFORMANCE.md explicitly cross-referencing docs/research/mvp/final/10-testing-acceptance-and-qa.md; and the diagram-coverage gap (§3) was partly closed — MVP2\_SHARED\_CORE.md and MVP2\_MOBILE\_APPS.md (the two documents this audit named as the highest-priority zero-diagram gaps) now each carry real Mermaid diagrams. **The findings below are preserved as the original, accurate-at-the-time audit record — read them as history for the items above, not as a current punch list.** MVP2\_DESKTOP\_APPS.md/MVP2\_WEB\_CLIENT.md still carry some superseded hex values alongside the new reconciliation note (not fully scrubbed) — that residual is real and still open. The design-system Phase-7 export/validation task list (§1) and the "mvp3/mvp\_final are TBD" note (§0) are ALSO now stale: mvp3//mvp\_final/ are populated (docs/research/mvp3/MVP3\_ENTERPRISE\_SCALE.md, docs/research/

mvp\_final/MVP\_FINAL\_GA\_READINESS.md), and Phase-7 status should be re-verified against docs/design/ directly rather than trusted from this snapshot.

## 0. Purpose, method, and constraints

This document is an independent, read-only audit across three normally-separate corpora: the built design system (docs/design/), the Phase-2 client-app planning corpus (docs/research/mvp2/), and the Phase-0/1 control-plane corpus (docs/research/mvp/, principally its final/ synthesis). docs/research/mvp3/ and docs/research/mvp\_final/ are placeholder (TBD.md, 1 line, unauthored) at the time of this audit and are noted but not analyzed further.

**This document does not edit docs/design/, docs/research/mvp/, docs/research/mvp2/, docs/research/mvp3/, or docs/research/mvp\_final/.** Every recommendation below names an exact file, section, and concrete action for the owning workstream to action independently. All findings are grounded in direct reads of the cited files as of this audit's timestamp — no claim below is a guess; where a status could not be verified from repo contents it is marked UNVERIFIED.

## 1. Design-system coverage audit

### 1.1 What exists today (docs/design/)

docs/design/README.md (the master index, 250 lines) documents a design system covering 8 client platforms (macOS/Windows/Linux via Tauri v2 + React; Android/ iOS/HarmonyOS via Flutter; Aurora OS via Qt6/QML; Web Extension via MV3 + React), a teal brand identity (#00897B), a light+dark authored theme pair, 5 built-in palette presets + custom override, and ~70 named design tokens across color/ typography/spacing/radius/elevation/motion domains. Phases 1–6 of its Implementation Checklist are all checked complete: token architecture, core + specialized components, screen layouts (including an "Admin Dashboard (Tauri)" screen and an onboarding flow), interaction/animation specs, and the four OpenDesign deliverables (DESIGN.md, tokens.css, manifest.json, components.html).

**Actual file inventory verified:**

| Path                                           | Role                            | Lines / notes |
|------------------------------------------------|---------------------------------|---------------|
| docs/design/<br>opendesign/helix/<br>DESIGN.md | 9-section<br>OpenDesign<br>spec | 553 lines     |

| Path                                                                       | Role                                                             | Lines / notes                                                           |
|----------------------------------------------------------------------------|------------------------------------------------------------------|-------------------------------------------------------------------------|
| docs/design/opendesign/helix/tokens.css                                    | Compiled CSS custom properties, --hx-* prefix                    | 8,966 bytes                                                             |
| docs/design/opendesign/helix/manifest.json                                 | OpenDesign manifest                                              | brand #00897B, accessibleWcagAA: true (claimed, unvalidated — see §1.3) |
| docs/design/opendesign/helix/components.html                               | Interactive component reference                                  | 15,499 bytes                                                            |
| docs/design/tokens/color.json, typography.json, spacing.json               | Flat (non-tiered) token JSON                                     | primary/accent/semantic/latency/light/dark/overlay groups               |
| docs/design/components/README.md, screens/README.md, interaction/README.md | Component, screen, interaction specs                             | 248 / 596 / 352 lines                                                   |
| docs/design/exports/*                                                      | 12 files: 4 doc-sets × {html,pdf} + 2 PNGs + 1 Figma-tokens JSON | see §1.3                                                                |

docs/design/opendesign/helix/{assets,preview,source}/ — declared in the README's "File Structure" diagram — **do not exist on disk**. This is a minor, low-cost doc/reality drift the design-system owner should either populate or strike from the documented structure.

## 1.2 Finding #1 (most important) — three mutually-inconsistent brand-color systems across the product

The single highest-value finding of this audit: there are currently **three different, independently-authored brand-color specifications** for the same product, and none references another as its source of truth.

1. docs/design/opendesign/helix/tokens.css + docs/design/tokens/color.json (**canonical, built**) — brand primary is **teal #00897B** (--hx-primary-500), secondary accent cyan #00BCD4.
2. docs/research/mvp2/MVP2\_UI\_UX\_SPEC.md §2.1 (lines 130-147) — defines an independent token tree (tokens/colors/primary.json,

prefix `--helix-*`, not `--hx-*`) with the **same hex values** as (1) (`--helix-primary-500: #00897B`). Values agree; naming convention and directory taxonomy do not — this is a duplicate-source risk, not yet a value conflict.

3. `docs/research/mvp2/MVP2_MOBILE_APPS.md §5.1` (lines 2654–2743, the Flutter HelixTheme Dart class) — hardcodes **indigo #6366F1** as `primaryColor`, fed directly into `ColorScheme.fromSeed()` for both the light and dark Material 3 themes. This is the color Android/iOS/HarmonyOS will actually render.
4. `docs/research/mvp2/MVP2_WEB_CLIENT.md §7.2` (lines 2074–2124, the shared `styles/theme.css` consumed by the extension, admin panel, and PWA) — hardcodes **blue #3B82F6** (`--helix-primary`) and **purple #8B5CF6** (`--helix-secondary`). This is the color the Web Extension, Admin Panel, and PWA will actually render.
5. `docs/research/mvp2/MVP2_DESKTOP_APPS.md §5.7` (lines 2351–2387, the Tauri `styles.css` dark/light custom properties) — hardcodes a **"Flat UI Colors"** palette (`#27ae60`/`#2ecc71` green accent, `#e74c3c` red, navy `#1a1a2e` dark background), with token names (`--bg-primary`, `--accent`) that don't even share the `--hx-/--helix-` prefix used elsewhere. This is what macOS/Windows/Linux will actually render.
6. `docs/research/mvp/final/v10-design/color-system.md` (a *different*, forward-looking corpus — read-only for this audit, part of `mvp/`) makes a **deliberate, reasoned, documented decision for a fourth color: "Deep indigo-blue as the brand," helix.500 #3D5AF1** (line 57–93), explicitly because "blue is the near-universal secure/privacy tool color." This document plans a *future* `vasic-digital/helix_design` submodule that would supersede `docs/design/` structurally (it specs the identical `opendesign/helix/{DESIGN.md, tokens.css, manifest.json}` folder shape `docs/design` already ships) — but its brand color decision was never reconciled with the teal already implemented in `docs/design/`.

Net effect: **five files, five different primary brand colors** (teal, unnamed- matching-teal, indigo `#6366F1`, blue `#3B82F6`, flat-green `#27ae60`, plus a sixth "official-sounding" indigo-blue `#3D5AF1` in the forward-looking `helix_design` spec). Semantic state colors (connected/connecting/disconnected) do independently converge on the same Material-derived hexes (`#4CAF50`/`#FF9800`/ `#F44336`) across most sources — the divergence is specifically the **brand primary**, which is the color every "Connect" button, focus ring, and app icon in the product will use.

### **Recommendation (for the mvp2/ and design-system owners, not this document's author):**

1. Operator decision required first: which brand color is canonical — teal `#00897B` (already built + exported in `docs/design/`) or indigo-blue `#3D5AF1` (the `mvp/final/v10-design` reasoned recommendation)? This is a §11.4.66-class blocking decision this audit surfaces but does not resolve.

2. Once decided, MVP2\_MOBILE\_APPS.md §5.1 (lines 2661–2667): replace the hardcoded HelixTheme.primaryColor/primaryDark/accentColor literals with values generated from the canonical token source (either import docs/design/opendesign/helix/tokens.css values directly, or — once it exists — the dist/compose/dist/dart polyglot export mvp/final/v10-design already specs).
3. MVP2\_WEB\_CLIENT.md §7.2 (lines 2074–2124): replace the invented --helix-primary/--helix-secondary HSL literals with a direct @import of docs/design/opendesign/helix/tokens.css (already compiled, already shipped — no reason for the web client to re-derive its own palette).
4. MVP2\_DESKTOP\_APPS.md §5.7 (lines 2351–2387): replace the "Flat UI Colors" custom-property block wholesale with the canonical tokens.css import; the current block doesn't share the brand color OR the naming convention with any other platform.
5. MVP2\_UI\_UX\_SPEC.md §1.2/§2 (lines 44–212): since its color VALUES already match canonical, the fix is cheaper — add one line stating "sourced from docs/design/opendesign/helix/tokens.css; do not re-declare" and delete the duplicate token-tree diagram, or explicitly note it is a *design intent* document (pre-dating the built system) now superseded by docs/design/.

### 1.3 Finding #2 — Phase 7 checklist in docs/design/README.md is stale; actual status is better than documented for 3 items and unstarted for 3 others

The README's "Phase 7: Export & Validation" checklist shows all 7 items unchecked. Direct inspection of docs/design/exports/ (12 files, all present) shows this is **materially out of date**:

| Checklist item                           | README status | Actual status (verified)                                                                                                          |
|------------------------------------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------|
| Export DESIGN.md → PDF                   | unchecked     | <b>DONE</b> — HelixVPN-Design-System.pdf (46,707 bytes) exists                                                                    |
| Export components.html → PNG screenshots | unchecked     | <b>PARTIAL</b> — HelixVPN-Components-Dark.png + -Light.png exist (2 whole-page screenshots), but not per-component/per-state PNGs |
| Export all documentation to PDF/HTML     | unchecked     | <b>DONE</b> — all 4 doc-sets (Design-System, Component-Library, Screen-Wireframes, Interaction-Specs) have both .html and .pdf    |
| Visual regression golden screenshots     | unchecked     | <b>NOT STARTED</b> — no golden/ directory, no snapshot-diff harness, no qa/golden/*.png found anywhere under docs/design/         |

| Checklist item                    | README status | Actual status (verified)                                                                                                                                                                                                                                  |
|-----------------------------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| WCAG 2.1 AA contrast validation   | unchecked     | <b>NOT STARTED</b> — no automated contrast-checker script or report found; manifest.json claims "accessibleWcagAA": true but this is an unvalidated assertion, not a computed proof                                                                       |
| Cross-platform consistency review | unchecked     | <b>NOT STARTED</b> — no review artifact found (and per §1.2 above, would currently FAIL — the platforms are NOT color-consistent)                                                                                                                         |
| Figma design file generation      | unchecked     | <b>PARTIAL</b> — HelixVPN-Figma-Tokens.json exists but is a <b>Figma Tokens Studio plugin import file</b> ("schema": "@figma/plugin-tokens"), not a generated .fig design file with laid-out frames/components. No .fig file exists anywhere in the repo. |

**Recommendation — concrete Phase 7 completion task list for the design-system owner**, each with acceptance criteria:

1. **Update the README checklist now** to reflect items 1 and 3 as done, items 2 and 7 as partial (with a one-line note on what remains), at zero engineering cost — this alone removes a false "0/7 done" signal from the master index.
2. **Per-component/per-state PNG export.** Acceptance: one PNG per (component × load-bearing state × {light,dark}) cell rendered from components.html, committed under docs/design/exports/components/, with a regeneration script (not just the two current whole-page screenshots).
3. **Golden-screenshot visual regression.** Acceptance: a committed golden/ baseline directory, a script that renders components.html (or platform builds, once they exist) and diffs against the baseline within a stated perceptual tolerance, and a documented "re-bless" procedure for intentional changes. docs/research/mvp/final/v10-design/visual-regression-and-qa.md (read-only reference — part of mvp/) already specs a fully worked gate ledger (DS-GOLDEN-MATCH, DS-GOLDEN-COVERAGE, CM-NO-LABEL-OVERLAY, CM-hit-target-44) for a *future* submodule; the design-system owner should treat that as a design reference to adapt for docs/design/'s current scope, not blindly import (that spec targets a not-yet-existing helix\_design submodule with Flutter/Swift/Compose/ArkTS/C-Qt targets; docs/design/ today is CSS/HTML-only).

4. **WCAG 2.1 AA contrast validation.** Acceptance: every (text, non-text) pair declared in docs/design/tokens/color.json (both light and dark blocks) has a computed contrast ratio  $\geq 4.5:1$  (body text) /  $\geq 3:1$  (large text / UI components), captured in a generated report (e.g. docs/design/exports/HelixVPN-Contrast-Report.json), with a script (not a manual claim) backing the manifest.json "accessibleWcagAA": true field.
5. **Cross-platform consistency review.** Acceptance: a single document comparing the *actually-rendered* token values across every platform surface (once mvp2/'s platform docs are reconciled per §1.2) — this item is currently blocked on §1.2's brand-color reconciliation and should be sequenced after it, not before.
6. **Figma design file generation.** Acceptance: either (a) confirm the Figma-Tokens-Studio-plugin import path is the intended deliverable and re-word the checklist item to say so precisely (avoids a repeat of this exact "stale/ambiguous checklist" problem), or (b) generate an actual .fig file with token-driven component frames if a real Figma artifact is required for handoff to visual designers.

## 1.4 Finding #3 — the Admin/Console surface and the PWA companion are unaccounted-for in the design system's 8-platform coverage

docs/design/README.md's "Platform Coverage" table (§2) lists exactly 8 platforms; none of them is an admin/console surface. Yet:

- docs/design/screens/README.md §5 (lines 533–564) specs a full "Admin Dashboard (**Tauri**)" screen.
- docs/research/mvp2/MVP2\_WEB\_CLIENT.md (lines 90, 1361, 2065–2067, 2514, 2566) plans the admin surface as a **Next.js 14 web app** (packages/ admin-panel/, deployed to Vercel) — not Tauri.
- docs/research/mvp/final/v10-design/00-overview-and-submodule.md §1.1/§9.2 (read-only reference) calls the same surface "**Console** (admin web app)" — again web, consumed via dist/css/helix.css, not Tauri.
- docs/research/mvp2/MVP2\_WEB\_CLIENT.md §5 (lines 1542–1561) also plans a **PWA Companion** (React + Vite PWA plugin) as a *ninth* client surface with no VPN capability of its own — also absent from docs/design/'s platform table entirely.

**Recommendation:** the design-system owner should either (a) add "Admin/ Console" and "PWA Companion" as explicit rows to docs/design/README.md §2's Platform Coverage table with their correct framework (web/Next.js, not Tauri — fix the mislabel in docs/design/screens/README.md §5's heading at the same time), or (b) explicitly scope them out with a one-line rationale if they are considered out of the current design-system's scope. Either way,

the current silent omission plus the Tauri mislabel is a documentation-accuracy gap that will confuse whoever builds the admin surface next.

## 1.5 Capability × corpus coverage table

| Design-system capability                                 | docs/design/ (canonical, built) | mvp/ Console/ Admin (Phase 0/1)                                               | mvp2 Tauri Desktop (macOS/ Win/ Linux)                     | mvp2 Flutter Mobile (Android/ iOS/HarmonyOS)                      |
|----------------------------------------------------------|---------------------------------|-------------------------------------------------------------------------------|------------------------------------------------------------|-------------------------------------------------------------------|
| Explicit reference to docs/design/ or "OpenDesign"       | — (source)                      | Yes, extensively (v10-design/, distinct corpus)                               | <b>No</b>                                                  | <b>No</b>                                                         |
| Brand color matches canonical teal #00897B               | Yes (source)                    | No — proposes indigo-blue #3D5AF1 instead (§1.2 item 6)                       | No — flat-UI green/red/blue (§1.2 item 5)                  | No — indigo #6366F1 (§1.2 item 3)                                 |
| Uses platform-native theming idiom correctly             | N/A                             | UNVERIFIED                                                                    | Partial — custom CSS vars, no Fluent/native bridging noted | Yes — Material 3 ColorScheme.fromSeed, Cupertino on iOS           |
| Light + dark themes both authored                        | Yes                             | Yes (v10-design DS-I3)                                                        | Yes (own palette, §1.4)                                    | Yes (own palette)                                                 |
| Semantic connection-state colors consistent w/ canonical | Yes (source)                    | Own generic state.* tokens, values differ (§color-system.md)                  | Yes — matches #4CAF50/ #FF9800/ #F44336                    | Partial — reuses Material greens/ ambers but different hex shades |
| WCAG 2.1 AA contrast validated                           | <b>No</b> (§1.3)                | Computed + cited per pair in color-system.md (not yet implemented, spec only) | Not mentioned                                              | Not mentioned                                                     |
|                                                          | N/A                             |                                                                               | No                                                         | No                                                                |

| Design-system capability                      | docs/design/ (canonical, built) | mvp/ Console/ Admin (Phase 0/1)         | mvp2 Tauri Desktop (macOS/ Win/ Linux) | mvp2 Flutter Mobile (Android/ iOS/HarmonyOS) |
|-----------------------------------------------|---------------------------------|-----------------------------------------|----------------------------------------|----------------------------------------------|
| Component token binding cited by file+section |                                 | v10-design/ component-library.md (spec) |                                        |                                              |

## 2. Testing & QA strategy consistency audit

### 2.1 Phase 0/1 (docs/research/mvp/final/10-testing-acceptance-and-qa.md) — the strategy in force

This document (1,065 lines, Revision 2) is explicit, mechanically enforced, and demands real runtime evidence rather than green CI:

- **Doctrine (§0):** "the operative bar for every HelixVPN test is not 'the assertion returned true' but 'a packet, a pcap, a counter delta, or a rendered frame — captured during execution — proves the user-visible security property held.'" Five named bluff classes (B1 config-only PASS, B2 absence-of-error PASS, B3 wrong-plane PASS, B4 stale-state PASS, B5 unvalidated-analyzer PASS) are each mapped to a specific guard.
- **Real infrastructure, not mocks, above the unit layer (§1, §5.2):** mocks are permitted "only" in UNIT tests; INT tests boot real Postgres+Redis via the containers submodule (rootless Podman, §11.4.161); E2E tests run a real Linux netns rig (client/gateway/connector namespaces) with real nftables-simulated DPI blocking and real WireGuard handshakes, asserting on captured pcaps and curl body hashes — not on log lines claiming success.
- **Self-validated analyzers (§3.3):** every analyzer (leak detector, OCR verdict, pcap classifier) ships a golden-good + golden-bad fixture pair so the analyzer itself cannot rubber-stamp a broken feature.
- **16 required test-type families / 18 codes (§2):** UNIT, INT, E2E, FA, SEC, STRESS, CHAOS, CONC, RACE, MEM, BENCH, PERF, UI/UX, REC (recorded evidence + vision verdict), CHAL/ HQA (Challenge-bank scoring, independent of the test's own exit code). DDOS/SCALE are the only two explicitly and honestly

deferred (NOT\_APPLICABLE: single-node-selfhost, re-arming in Phase 2).

- **A git-tracked SQLite coverage ledger (§6)** with a schema CHECK constraint that makes a bluffed "verified" row structurally impossible (state = 'AUTONOMOUS\_VERIFIED' requires a non-empty evidence\_path).
- **No remote CI (§4, §9):** "There is no active .github/workflows/\*.yml or .gitlab-ci.yml in any HelixVPN repo" — all gates run locally via git hooks (pre-commit = UNIT + lint; pre-push = INT + SEC subset; make qa = full pyramid), per the (now-current) constitution mandate §11.4.156.

This is a rigorous, concrete, VPN-appropriate strategy: real WireGuard tunnels, real Postgres RLS multi-tenant isolation tests, real pcap-based kill-switch/ DNS-leak proofs, real iperf3 throughput evidence.

## 2.2 Phase 2 (docs/research/mvp2/MVP2\_SECURITY\_PERFORMANCE.md §8, MVP2\_IMPLEMENTATION\_ROADMAP.md) — the strategy currently documented

MVP2\_SECURITY\_PERFORMANCE.md §8 (lines 1812–2111) is reasonably concrete on its own terms — it names real tools (tcpdump, Wireshark, iperf3, dnsleaktest.com, browserleaks.com/webRTC, tauri-driver, XCUITest, Espresso, Playwright) and includes a 14-item penetration-test checklist (§8.6) and a Coverage-Targets table with per-module percentage floors (§8.1).

MVP2\_IMPLEMENTATION\_ROADMAP.md uses "mock" sparingly and mostly reasonably (a mock TUN device for root-free unit testing, a mock core for an early milestone's UI bring-up — not as final acceptance evidence).

However, directly comparing it against §2.1's doctrine surfaces real inconsistencies:

1. **Zero anti-bluff doctrine of any kind.** A repo-wide search across MVP2\_SECURITY\_PERFORMANCE.md, MVP2\_IMPLEMENTATION\_ROADMAP.md, MVP2\_ARCHITECTURE.md, and MVP2\_SHARED\_CORE.md for "anti-bluff", "captured evidence", "golden-bad", "self-validat\*", or "evidence\_path" returns **zero hits** in all four files. There is no explicit rule against config-only PASS, absence-of-error PASS, or trusting a harness's own exit code — the exact three bluff classes (B1/B2/B3) that Phase 0/1's doctrine names and specifically guards against.
2. **The DNS/kill-switch leak tests (§8.3) are single-shot, not liveness-over- a-window.** E.g. the kill-switch test (lines 1970–1987) starts a timer, polls curl in a loop, and asserts the elapsed time — reasonable, but it never captures or inspects a pcap to *prove* zero plaintext egress during the gap (Phase 0/1's rig/killswitch\_drop.sh explicitly captures a pcap and asserts

zero non-loopback packets **and** zero :53 DNS packets — a materially stronger proof of the exact same claim).

3. **§8.7 CI Test Matrix assumes remote CI cadences** ("Daily", "Weekly", "Per release" per platform) that directly conflict with the project's own (more recent) constitution mandate §11.4.156 — all CI/CD automation disabled, local-only gates — which Phase 0/1's testing doc already implements (§2.1 above). This is a dateable, fixable inconsistency: mvp2's testing content predates §11.4.156's addition and has not been revisited against it.
4. **No coverage-ledger / per-feature evidence-state tracking equivalent.** Phase 0/1's git-tracked SQLite schema with a CHECK constraint preventing a bluffed PASS row has no analogue anywhere in mvp2/ — coverage is expressed only as static percentage targets (§8.1), which is a much weaker guarantee (100% line coverage of a function that asserts nothing is still "100%").
5. **Mocks are not confined to a single named layer.** Phase 0/1 explicitly states "mocks are permitted only at [the UNIT] layer" (§11.4.27). Mvp2 has no equivalent explicit boundary statement — its mock usages are currently benign (early scaffolding), but nothing in the document would flag a future contributor who mocks the VPN core at the integration-test layer as having violated project policy, because no such policy is stated in mvp2/.

## 2.3 Recommendation — task list to unify testing philosophy project-wide

This is written for **this project's actual stack** (Rust core + Go control plane + WireGuard/MASQUE tunnels + Postgres/Redis + 8 client platforms across Tauri/Flutter/Qt6/React) — no fictitious tooling is proposed.

1. **Adopt one written testing-philosophy statement at the project root** (e.g. docs/TESTING\_PHILOSOPHY.md, outside the scope this document edits) that states, once: "every shipped feature is validated by evidence that it actually works end-to-end for a real user or operator, not merely by tests passing in isolation" — and have both docs/research/mvp/final/ 10-testing-acceptance-and-qa.md's successor implementation AND the mvp2/ client docs reference it, rather than mvp2/ re-deriving its own philosophy independently (as MVP2\_SECURITY\_PERFORMANCE.md §8 currently does).
2. **Backend/control-plane (Rust/Go) — concrete, already-partially-designed mechanisms to adopt project-wide:**
  - Integration tests boot real Postgres + Redis via testcontainers-go / testcontainers-rs (or the project's own containers submodule boot/health helpers already spec'd in mvp/final) — never a mocked DB layer above unit tests.

- WireGuard/MASQUE reachability tests run against a real tunnel in a Linux network-namespace rig (as mvp/final already specs) with tcpdump/ tshark-captured pcaps as the evidence artifact for every kill-switch, DNS-leak, and default-deny claim — not a timer-only or log-line-only assertion (fixes §2.2 item 2 above).
3. **Client platforms — concrete E2E mechanisms per platform, driving the real UI, not mocked:**
    - **Tauri desktop (macOS/Windows/Linux):** tauri-driver + WebDriver (already named in MVP2\_SECURITY\_PERFORMANCE.md §8.5) — keep it, but require every E2E run to assert against the real Rust core's status stream (not a stubbed status), and capture a screen recording of the connect/disconnect flow as evidence, consistent with the design-system's UI/UX/REC test-type in mvp/final.
    - **Flutter (Android/iOS/HarmonyOS):** flutter\_test widget + golden tests for components, plus integration\_test package driving the real flutter\_rust\_bridge FFI bridge against the real Rust core (not a Dart- side fake), on a real device or emulator/simulator for platform-specific assertions (VpnService/NEPacketTunnelProvider), matching Phase 0/1's MEM test-type requirement that iOS memory-ceiling tests run on real hardware, never a simulator.
    - **Qt6/QML Aurora:** Qt Test / QML TestCase driving the real C++ backend over the real D-Bus/VpnService-equivalent Aurora API, not a QML-only mock.
    - **Browser Extension / PWA / Admin panel:** Playwright (already named for Web in MVP2\_SECURITY\_PERFORMANCE.md §8.7) driving the real built extension/PWA in a real browser profile, asserting on real network requests (via Playwright's network interception as an *observer*, not a stub) rather than mocked chrome.\* APIs.
  4. **State explicitly, in both corpora, which test layer mocks are permitted at** (unit only — matching Phase 0/1's existing rule) and add a one-line cross-reference from MVP2\_IMPLEMENTATION\_ROADMAP.md's existing "mock" usages (lines 263, 291, 642, 2445) confirming each is scaffolding-only, not final acceptance evidence.
  5. **Resolve the CI-cadence conflict (§2.2 item 3):** update MVP2\_SECURITY\_PERFORMANCE.md §8.7's "CI Test Matrix" to state the gates run locally (git hooks / make test / make qa) at the stated cadence, not via .github/workflows/\*.yml or equivalent remote CI, to align with the project's current no-remote-CI decision already implemented in mvp/final.
  6. **Extend (don't invent) a shared coverage-ledger concept.** If Phase 0/1's git-tracked SQLite coverage-ledger schema (feature × test-type × evidence- state, docs/research/mvp/final/10-testing-acceptance-and-qa.md §6) is adopted for the control plane, the client-app workstream should add its own feature\_id rows (e.g. F-CONNECT-FLOW-DESKTOP, F-KILL-SWITCH-MOBILE) to the *same* ledger rather than mvp2/ maintaining a separate,

unlinked coverage-tracking mechanism (currently mvp2/ has none at all).

## 3. Diagram/artifact completeness sweep

### 3.1 Corpus-wide diagram coverage

| Corpus                                                | Total .md files                                                               | Files with $\geq 1$ Mermaid block | Coverage |
|-------------------------------------------------------|-------------------------------------------------------------------------------|-----------------------------------|----------|
| docs/research/mvp/ (incl. final/ and all sub-volumes) | 142                                                                           | 100                               | 70%      |
| docs/research/mvp2/                                   | 39 (includes an exact-duplicate extracted-archive copy under helix_vpn_mvp2/) | 2                                 | 5%       |
| docs/research/mvp3/                                   | 2 (placeholder TBD.md, unauthored)                                            | 1                                 | n/a      |
| docs/research/mvp_final/                              | 2 (placeholder TBD.md, unauthored)                                            | 1                                 | n/a      |
| docs/design/                                          | 10                                                                            | 0                                 | 0%       |

Two corrections worth noting for whoever next audits this: (a) mvp2/ ships an exact duplicate of its own top-level docs under docs/research/mvp2/ helix\_vpn\_mvp2/docs/ (apparently an extracted copy of the sibling .zip/ .tar.gz archives in the same directory) — every file-level recommendation in §1/§2 above applies equally to both copies, and the mvp2/ owner should consider whether the extracted copy needs to exist as tracked, duplicate content at all. (b) Within docs/research/mvp/final/, the 16 canonical top-level synthesis documents (data-plane, control-plane, client-core-and-ui, security, phase WBS docs, testing, SPECIFICATION.md) are **well covered** — 12 of 16 have Mermaid diagrams; only 11-deep-research-appendix.md, 99-source-coverage-ledger.md, MASTER\_INDEX.md, and REFINEMENT\_NOTES.md lack them, which is reasonable given their prose/index/ledger nature. The v10-design/ sub-volume (design system spec for the future helix\_design submodule) also uses Mermaid extensively. The 70%-vs-100% gap in the overall mvp/ number is almost entirely the 11 raw, pre-synthesis top-level LLM-brainstorm documents (00\_VPN\_Initial\_Res.md through

11\_VPN\_MST.md, 0-2 diagrams each) — these are superseded source material, not the current spec, so their diagram gap is low-priority.

The real gaps are docs/research/mvp2/ and docs/design/ — both near-zero.

### 3.2 Top documents most in need of a diagram (recommendation, not an edit)

Ranked by (content criticality × current diagram absence × document size):

1. **docs/research/mvp2/MVP2\_SHARED\_CORE.md** (2,482 lines, 0 diagrams) — the Rust core / FFI bridge / protocol-handling document. This is the single most architecturally central mvp2/ document and has no diagram at all. **Recommended:** an **architecture diagram** (core crate boundaries, FFI surface to each platform binding) plus a **state-machine diagram** for the connection-state FSM (the same FSM every platform's UI renders).
2. **docs/research/mvp2/MVP2\_MOBILE\_APPS.md** (4,924 lines, 0 diagrams) — the largest single document in the entire mvp2/ corpus, covering three platforms' VPN-service integration (VpnService, NEPacketTunnelProvider, VpnExtensionAbility). **Recommended:** a **sequence diagram** per platform for the connect/enroll/reach flow, since the three platforms' lifecycle callbacks differ materially (§ noted at MVP2\_MOBILE\_APPS.md's own "Platform Differences" section) and prose alone under-communicates the divergence.
3. **docs/research/mvp2/MVP2\_DESKTOP\_APPS.md** (3,225 lines, 0 diagrams) — Tauri IPC ↔ Rust core ↔ platform VPN API (WFP on Windows, Network Extension on macOS, wireguard-tools on Linux). **Recommended:** a **deployment-topology / architecture diagram** showing the Tauri webview ↔ Rust backend ↔ OS-VPN-API boundary per OS.
4. **docs/research/mvp2/MVP2\_WEB\_CLIENT.md** (2,785 lines, 0 diagrams) — four distinct web surfaces (extension, admin panel, PWA, plus the shared component package) sharing one packages/ monorepo. **Recommended:** an **architecture diagram** of the monorepo's package graph (which package depends on which) — the current ASCII directory tree communicates layout but not the dependency/data-flow relationships between the four surfaces.
5. **docs/research/mvp2/MVP2\_AURORA\_CLIENT.md** (2,564 lines, 0 diagrams) — Qt6/QML + C++ backend for Aurora OS, the platform the corpus itself (and mvp/final's Phase-3 WBS) flags as the highest platform risk. **Recommended:** an **architecture diagram** (QML UI ↔ C++ backend ↔ Aurora VPN plugin API).
6. **docs/research/mvp2/MVP2\_SECURITY\_PERFORMANCE.md** (2,304 lines, 0 diagrams) — threat model, kill-switch, and DNS-leak-

prevention logic described entirely in prose/tables.

**Recommended:** a **sequence diagram** for the kill-switch trip → firewall-seal → reconnect flow, and a small **data-flow diagram** for the threat model (attacker positions vs. the defenses in §8.6's pen-test checklist).

7. `docs/research/mvp2/MVP2_IMPLEMENTATION_ROADMAP.md` (2,553 lines, 0 diagrams) — a 34-week, multi-team roadmap.

**Recommended:** a **Gantt-style or dependency diagram** (Mermaid gantt or a phase-dependency flowchart) showing which weeks/teams block which — currently only expressed as sequential prose headings, making cross-team blocking dependencies hard to see at a glance.

8. `docs/design/opendesign/helix/DESIGN.md` (553 lines, 0 diagrams, the canonical 9-section OpenDesign spec) — **Recommended:** an **architecture diagram** of the token pipeline (primitive color/type/space values → semantic role tokens → component tokens → per-platform consumption), directly analogous to the tiered diagram `mvp/final/v10-design/00-overview-and-submodule.md` §5.1 already has for its own (different, future) token model — `docs/design/`'s current flat (non-tiered) token JSON would benefit from the same visual treatment even without adopting the tiered schema itself.

9. `docs/design/interaction/README.md` §1 "**Connection Flow (Critical Path)**" (lines 7–29) — currently a hand-drawn **ASCII text diagram**, not a real diagram, for the single most important interaction in the product. **Recommended:** convert to a Mermaid stateDiagram-v2 (Disconnected → Connecting → Connected → Disconnecting → Disconnected, with the per-phase timing/visual annotations from the adjacent Timing Table attached as state notes) — this is a low-effort, high-value fix since the content already exists in prose/ASCII form.

10. `docs/design/screens/README.md` (596 lines, 0 diagrams, but does use ASCII-art wireframes for each screen, which is appropriate for static single-screen layouts) — **Recommended:** add one **navigation/flow diagram** (Mermaid flowchart) showing screen-to-screen transitions (e.g. Onboarding → Home → Server Selection → Settings → back to Home), which the current per-screen wireframes do not communicate as a set.

---

## Summary of cross-cutting themes

Three findings recur across all sections of this audit and are worth the operator's attention as a single decision, not three separate ones:

1. **The mvp2/ client-platform corpus was authored without reference to docs/design/** (or to the OpenDesign system, or to any shared testing philosophy) — every platform independently reinvented its own token set and its own testing approach, at

different levels of rigor and with mutually inconsistent brand colors. This is the direct, avoidable result of the two corpora being developed as separate workstreams without a cross-reference contract.

2. **A parallel, more rigorous, and more recent design-system + testing spec already exists inside `mvp/final/` (`v10-design/*` and `10-testing-acceptance-and-qa.md`)** that was itself authored without reconciling its brand-color decision against the already-built `docs/design/`, and that plans infrastructure (`helix_design` submodule, git-tracked coverage-ledger DB) not yet reflected in `docs/design/` or `mvp2/` at all.
3. **None of the three corpora's owners currently has a mechanism to detect this kind of drift automatically** — every finding in this report required a manual, cross-corpus read to surface. Recommend the operator require a standing cross-reference check (even a lightweight one — e.g. a script that greps for brand-color hex literals across all three corpora and flags divergence) as a release-gate item once a canonical answer to "which brand color, which testing doctrine, which token schema" is chosen.